

Information Security Policy

Issue Date	Review Date	Version
October 2024	October 2029	7.0

Purpose

This policy defines information security protocols, procedures, and controls to protect to a consistently high standard, all electronic information assets held on and processed by Trust systems, staff, and contractors, from internal or external damage, either deliberately or accidentally.

Who should read this document?

All staff should familiarise themselves with this policy and its supporting policy documentation.

Key Messages

This policy will define the key roles and responsibilities in respect of managing the security of electronic and paper information held by the Trust.

Core accountabilities

Owner	D&I Chief Information Security Officer
Review	- D&I Service Management and Improvement Team (SMIT) - D&I Senior Leadership Group (SLG) - D&I Cyber Team - Caldicott & Information Governance Assurance Committee (CIGAC)
Ratification	Senior Information Risk Owner (SIRO)
Dissemination (Raising Awareness)	D&I Chief Information Security Officer
Compliance	- D&I Chief Information Security Officer - D&I Information Security Officer - D&I Cyber Team

Links to other policies and procedures

- Information Governance Policy.
- D&I Change Enablement Standard Operating Procedure.
- System Suppliers Remote Access Application Form.
- Network Security Policy.
- Internet Use Policy.
- NHSmial Acceptable Use Policy.
- Telecommunications Policy.
- Various System Level Security Policies.

Version History

1	July 2007	Initial Document
2	December 2007	Major review in line with ISO 27001 and IG Toolkit
3	March 2009	Reviewed and reformatted
4	January 2010	Reviewed and no changes made
5.1	March 2012	Revised and reformatted
5.2	May 2013	Minor amendment to job titles
5.3	February 2014	Minor amendment to job titles and Trust Documents
5.4	March 2015	Review and minor amendments

5.5	July 2015	Minor amendments to job titles and committee structure
5.6	August 2016	Minor amendments to name change of HSCIC to NHS Digital
6.0	January 2019	Added Electronic Storage and Transfer section
6.1	May 2021	Minor amendments and reference to NHSmail Acceptable Use Policy and N365 use.
6.2	November 2021	Minor amendments to NHSmail, AD credentials and MS Forms use.
6.3	April 2023	Minor amendments to core accountabilities, key legislation and standards
6.4	April 2024	Extended to October 2024
7	October 2024	Policy reviewed, minor amendments for general readability & formatting. Updated TOC and, updates on: • IM&T to D&I Services • Job titles • Committee structures • Printer use and paper disposal guidance • Personal use of Trust devices • Working from abroad • New digital forensics section • Inclusion of CIO role in Duties and digital forensics • References and associated document links

Equality, diversity, and inclusion is at the heart of the NHS strategy and for UHP this means ensuring we create an equitable organisation for colleagues, patients, and visitors. Our inclusion agenda recognises that everyone matters, as well as understanding that there are times when people, particularly those from protected groups (defined by the Equality Act 2010 - age; disability; gender reassignment; marriage and civil partnership; pregnancy and maternity; race; religion or belief; sex; sexual orientation), may face unfairness and discrimination.

We have a moral responsibility to work in a way that creates fairness as well as a legal and public sector equality duty which we take very seriously. We will always aim to create policies and practices that eliminate workplace discrimination and health inequalities, as well as strengthening our relationships within the community and with our colleagues who may identify with one or more protected groups.

A diverse workforce improves the experience of our patients and creates an environment where everyone belongs and feels included. UHP recognise that we all play a part in providing exceptional care to patients as well as showing kindness and compassion to patients and colleagues.

An electronic version of this document is available in the Document Library. Larger text, Braille and Audio versions can be made available upon request.

Table of Contents

1. Introduction	5
2. Purpose	5
Confidentiality	5
Integrity	5
Approach	6
3. Definitions	7
Information System	7
Information Asset	7
Information Asset Owner	7
Information Asset Administrator	7
Information Governance (IG)	7
4. Duties	7
Trust Board	7
Senior Information Risk Owner (SIRO)	7
Digital & Innovation (D&I) Services Service Management and Improvement Team (SMIT) and D&I Services Senior Leadership Group (SLG)	7
Caldicott Guardian	8
Chief Information Officer (CIO)	8
Chief Information Security Officer (CISO)	8
Cyber Security Team	8
All Managers	8
All Staff	8
Information Governance Committee Structure	8
Head of Information Governance/Data Protection Officer (DPO)	8
5. Information Security Training	8
6. Control of Information Assets	9
7. Electronic Storage and Transfer	9
8. Access Controls	9
9. Electronic Software	10
10. Instant Messaging Software	10
11. Equipment Security and Controls	11
12. Access to Network Services	12

13. Remote Access.....	12
14. Antivirus and Malware Protection.....	12
15. Removable Storage Devices and Media	12
16. Internet, Email and Cloud Storage	13
17. Change Control.....	13
18. Assurance.....	13
19. Business Continuity and Disaster Recovery.....	14
20. Security Incidents.....	14
21. Digital Forensics	14
22. Overall Responsibility for the Document.....	15
23. Dissemination and Implementation	15
24. Monitoring Compliance and Effectiveness.....	15
25. References and Associated Documentation.....	16
Appendix 1. Dissemination and Review Checklist.....	18
Appendix 2. Equalities and Human Rights Impact Assessment.....	19

1. Introduction

University Hospitals Plymouth NHS Trust acknowledges that information is an asset; therefore, it is within its interest to ensure that the information it holds, in whatever form, is appropriately governed and protected in the interest of all its stakeholders.

It is therefore of paramount importance to ensure that, information is efficiently managed and that appropriate policies, procedures, management accountability and structures provide a robust governance framework for information management.

Personal health data is held by the Trust on the patient's behalf either electronically or in paper format so that their care can be delivered effectively.

The Trust is under an obligation to the individual to ensure that their personal information is:

- Recorded accurately
- Not modified or lost during storage or transfer
- Not disclosed to unauthorised individuals
- Made available when and where needed for its intended purpose
- Not processed for any other purpose other than intended

The Trust also depends on information systems for its business viability, using contract monitoring, financial, workforce, works, supplies and other departmental systems. The correct functioning of all these systems is critical to the efficient running of the organisation.

The security of information systems is therefore of fundamental importance to maintaining the continuity of health care provision and to preventing and minimising the impact of security incidents on the Trust. A secure information system enables sharing of information to the benefit of the individuals concerned and the organisation.

2. Purpose

The purpose of this Information Security Policy is to preserve:

Confidentiality

Access to data must be confined to those with specific authority to view the data.

Integrity

Information is to be complete and accurate. All systems, assets and networks must operate correctly, according to specification.

Approach

The Trust's approach to information security is predominately based on adherence to NHS Standards and the Cyber Assessment Framework aligned Data Security Protection Toolkit ([DSPT](#)), in addition to Clinical Safety Standards [DCB160](#) (Clinical Risk Management: its Application in the Deployment and Use of Health IT Systems) and [DCB129](#) (Clinical Risk Management: its Application in the Manufacture of Health IT Systems).

The ISO 27000 Series of Standards for Information Security Management Systems (ISMSs) and the UK's National Cyber Security Centre Cyber Essentials+ certification is recognised and incorporated into the Trust approach, but accreditation is not currently being pursued as these elements form a mainstay of the DSPT Framework.

Information must be available and delivered to the right person, at the time when it is needed.

It will establish and maintain the security and confidentiality of information assets, information systems, applications, and networks.

Key legislation and standards in respect of Information Security are the:

- UK Data Protection Act (2018)
- UK General Data Protection Regulation (GDPR) (2018)
- Caldicott Reviews 1997, 2012, 2016
- Copyright, Designs and Patents Act (1988)
- Computer Misuse Act (1990)
- Confidentiality: NHS Code of Practice 2003
- Health and Safety at Work Act (1974)
- Human Rights Act (1998)
- Regulation of Investigatory Powers Act (2000)
- Freedom of Information Act (2000)
- Health and Social Care Act (2000)
- Information Security Management: NHS Code of Practice
- Network Information Systems Regulations 2018
- NHS Records Management Code of Practice for Health and Social Care 2023
- Data Security and Protection Toolkit

As well as an obligation to the Trust, staff are also bound by the Codes of Conduct of their respective professional bodies and should refer to their respective organisations for details of their guidelines.

Individual systems will be required to implement and meet Information Standard Notices (ISNs) published by NHS England and be compliant with any other applicable legislation and regulations.

The NHS England Digital Technology Assessment Criteria (DTAC) for health and social care is considered a fundamental pre-requisite tool for new system suppliers, to ensure digital technologies meet our minimum baseline standards.

3. Definitions

Information System

An information system is a combination of hardware, software, infrastructure, and trained personnel organised to facilitate planning, control, coordination, and decision making in an organisation.

Information Asset

An information asset is a body of information, defined and managed as a single unit so it can be understood, shared, protected, and used effectively.

Information Asset Owner

Information Asset Owners (IAO) are senior individuals involved in running the relevant business. Their role is to understand and address risks to the information assets they “own” and provide assurance to the Senior Information Risk Owner (SIRO) on the security and use of those assets.

Information Asset Administrator

Information Asset Administrators (IAA) ensure that policies and procedures are followed, recognise actual or potential security incidents, consult their Information Asset Owners on incident management and ensure that information asset registers are accurate and up to date.

Information Governance (IG)

A framework bringing together the requirements and best practice that applies to the processing of personal/corporate data

4. Duties

Trust Board

It is the role of the Trust Board to define the Trust’s policy in respect of Information Security, considering legal and NHS requirements. The Board is also responsible for ensuring that sufficient resources are provided to support the requirements of the policy.

Senior Information Risk Owner (SIRO)

The Senior Information Risk Owner is an executive who is familiar with and takes ownership of the organisation’s information risk policy and acts as advocate for information risk on the Board. The Senior Information Risk Owner will also be responsible for the Information Governance agenda.

Digital & Innovation (D&I) Services Service Management and Improvement Team (SMIT) and D&I Services Senior Leadership Group (SLG)

These Teams are responsible for the review of this policy to ensure this policy is relevant and compliant.

Caldicott Guardian

The primary responsibility for the role of Caldicott Guardian is to safeguard and govern the uses made of patient information within the Trust and the transfer of personally identifiable information outside the Trust.

Chief Information Officer (CIO)

The Chief Information Officer reports directly to the Deputy Chief Executive / SIRO and is responsible for ensuring that the strategic plan and operational leadership is adopted, and appropriate mechanisms are in place in relation to Cyber and Information Security

Chief Information Security Officer (CISO)

The Chief Information Security Officer is responsible for production of and compliance with this policy. Policy compliance will be monitored using various tooling available to the Cyber Security Team. The CISO will initiate appropriate revisions in between the main policy review dates should changes in the security landscape emerge.

Cyber Security Team

The Cyber Security Team are responsible for coordination of information technology and cyber security under the guidance of the Chief Information Security Officer.

All Managers

Managers within the Trust are responsible for ensuring that the policy and its supporting standards are built into local processes and that there is ongoing compliance.

All Staff

All staff, whether permanent, temporary, or contractors are responsible for ensuring that they are aware of the requirements incumbent upon them and for ensuring that they comply with these requirements on a day-to-day basis.

Information Governance Committee Structure

The Trust has designated authority to the Caldicott & Information Governance Assurance Committee (CIGAC), chaired by the Senior Information Risk Officer to monitor the implementation and oversee the compliance of Information Governance and Information Security.

The Caldicott & Information Governance Assurance Committee provides Information Governance assurance to the Trust Board.

Head of Information Governance/Data Protection Officer (DPO)

Has overall managerial responsibility for the implementation, development and monitoring of the operational IG.

5. Information Security Training

The mandatory Data Security Awareness training contains key information security and governance principles which all staff are to complete annually.

Upon request the Information Governance Team will provide on-going awareness of information governance matters via the Trust official communication network. The Cyber Security team will provide additional training on cyber security related topics as requested.

The D&I Service Desk regularly publish bulletins when there is an identified information security issue and current threats and to identify phishing campaigns to ensure all staff can avoid any threats.

Through audit and compliance monitoring, staff may be identified as requiring additional information security training.

6. Control of Information Assets

Every information asset, (be it hardware, software, application, or data) will have a named Information Asset Owner who will have overall responsibility for the security of that asset.

Information Asset Administrators will be responsible for the day-to-day administration of the asset(s).

The D&I Service will maintain an Information Asset Register which is regularly reviewed by the Compliance Manager and Information Governance Team.

7. Electronic Storage and Transfer

In line with Department of Health and Social Care statements on a paperless NHS, where appropriate and viable, information shall be stored and transferred electronically using appropriate technology commensurate with the capabilities of the system.

Data-at-rest will be encrypted where it is not detrimental to the performance or operational characteristics of the system.

Electronic data transfers must be encrypted when traversing external networks or sent to individuals or organisations outside of the immediate Trust network.

Retention and disposal of electronic information should adhere to the [NHS Records Management Code of Practice](#) for Health and Social Care 2023 with records deleted in line with the retention schedule.

8. Access Controls

Staff are required to complete the D&I Service Registration Authority process to receive a network account. Individual registration processes may exist for other information assets and systems.

Only authorised staff and third-party contractors will be provided with access to information assets and information systems. Information Asset Owners will hold separate policies and registration processes where required and be responsible for ensuring authorised personnel have access only to areas appropriate to their business need. These policies will be defined in the System Level Security Policies.

Access to electronic information assets requires authentication via individual user account(s) or smartcards. Generic shared accounts must not be used as they lack audit and accountability. Exceptions must receive consent from Cyber Security Team.

Passwords are required to be strong in alignment with the [NHS Mail policy](#), including at least one numeric or special character and a mixture of lower and uppercase. Passwords must never be shared with other people. The information system should enforce password changes every 60-90 days if passwords are weak/short. Passwords can change every 365 days if they are deemed strong. The Cyber Security Team will periodically assess password compliance in annual penetration testing. The responsible Information Asset Administrator/System Owner will manage and audit access to electronic and paper information assets and provide assurances to the Information Asset Owner.

Third party contractors or suppliers who have a business need to access information systems and assets are required to apply for access in accordance with the Trust Network Security policy – Available on StaffHub.

System Managers will ensure that appropriate governance is in place for volunteers and people from other organisations. Systems Managers must ensure that their Systems comply with the NHS England MFA Policy.

9. Electronic Software

Staff must not install software on the organisation's property without permission from the D&I Service. Only software approved by the D&I Service may be installed on Trust systems and devices. Software will be installed by an approved Trust engineer or via the software management system Microsoft SCCM. Software purchased by the Trust remains the property of the Trust even when not installed and should never be transferred to non-Trust devices without prior written approval and transfer of license(s). All staff are required to comply with this policy. Staff breaching this requirement may be subject to disciplinary action.

The D&I Service are responsible for maintaining an effective software license compliance position. Where software is installed without a valid license it may be removed.

The D&I Service will conduct regular software audits and usage will be monitored and metered to aid in identifying software which is not in use and can be recovered for redeployment.

Trust devices are issued for work/Trust business purposes and are not issued for personal use. Trust devices must not be used for social purposes such as downloading films and TV series, gaming, gambling, or entertainment streaming services. The use of YouTube for work related activities is permitted. Trust issued devices are Trust property and must be returned at the end of employment.

10. Instant Messaging Software

In accordance with guidance published by NHS England – Transformation Directorate (December 2022), instant messaging was recognised as a useful tool in health and care settings to communicate with colleagues, particularly in emergency situations. The following should be considered to use this method safely and keep information confidential:

- Minimise the amount of personally identifiable information you communicate.
- Do not use instant messaging as a formal medical record.
- Any advice received on instant messaging should be transcribed and attributed in the case note.

- Instant messaging conversations may be subject to freedom of information requests or subject access requests.
- Your device must require a passcode and lock out after a short period of inactivity.
- Disable message notifications on your device's lock screen.
- Enable the remote-wipe feature in case your device is lost or stolen.
- Unlink any app from your photo library.

The Trust accredited and approved method for work related communications is MS Teams. MS Teams has an instant messaging function and includes the ability to message a single contact or groups. MS Teams is a mobile app with notifications that all staff can use within approved Information Security standards. The requirement to use any other communications system needs approval from D&I Services with support from the Information Governance team.

11. Equipment Security and Controls

To minimise loss of or damage to assets, equipment will be physically protected from security threats and environmental hazards, based on risk assessments by the Information Asset Administrator (IAA), who will provide support to the Information Asset Owner (IAO) to:

- Ensure that Information Governance policies and procedures are followed.
- Recognise potential or actual security incidents and escalate.
- Consult their Information Asset Owner on incident management and to ensure their information asset registers are accurate and up to date.

Any equipment assigned to individuals (e.g. laptop or mobile telephone) is the responsibility of that individual and all relevant precautions should be taken to ensure continued protection from data loss or theft. Individuals should not alter, modify, or remove equipment in a manner which exposes information to data loss, theft, or risk. Individuals must ensure that their equipment is kept up to date with the latest available software updates and patches as they are prompted and from Software Centre on their desktop. Rebooting devices daily enables regular updates to be applied, generally this is considered best practise.

It is the responsibility of individuals to ensure that D&I are immediately informed upon realising any electronic device has been lost or stolen and to report this to the Service Desk.

Trust electronic information assets will be managed by the D&I Service using appropriate systems and procedures and in accordance with the Network Security policy. A Configuration Asset Management Database of all electronic assets will be maintained in conjunction with an Information Asset Register which will be reviewed regularly for accuracy and completeness.

Mobile devices such as laptops, portable hard drives and smartphones will have either full disk encryption or encryption of data at rest by default during the build process. With encryption keys stored in Active Directory against the device record and managed by Intune, the Trust's Mobile Device Management (MDM) solution. All MDM managed mobile devices are encrypted at rest using manufacturer proprietary encryption.

Removable storage including external drives, memory sticks and CDs must be encrypted to AES 256bit standards.

Disposal of electronic information assets must be coordinated through the D&I Service. In cases of hardware disposal, hard drives will be removed and destroyed according to the safe disposal procedure.

Personal devices may not be used for the storage, processing or transmission of business or personal identifiable data. Certain removable storage devices defined by the D&I Service, purchased privately, may be used if they meet security and encryption requirements which are available upon request.

Staff should not connect Trust devices to their own printers when working from home. This is due to the risk of data being retained on the printer or in cloud storage. It is noted that many staff work from home and will need to take paper based personal data home with them. It is important that staff ensure a secure transfer between home and their place of work. Any paper records must be held securely whilst in the home environment and disposed of in confidential waste bins at the office and not at home.

12. Access to Network Services

Access to network services is restricted to Trust devices or third-party systems where prior approval from the D&I Service has been granted, in accordance with the Network Security Policy.

No personal devices are permitted to access the Trust network. The only exception to this rule is access provided by the guest wireless networks 'NHS WiFi' (NHS Guest), Eduroam' and 'GovWiFi' and remote access to Citrix, where devices are segregated from the Trust network using appropriate security protocols.

13. Remote Access

Remote access requirements are detailed in the Network Security Policy.

Any requests to work from abroad are managed by explicit country exemptions and therefore require line manager approval. Once this has been approved the D&I Cyber Security Team can investigate the country chosen and determine whether it is secure to connect and use D&I hardware and software, and to ensure it is approved by NHSE and NHSMail. This request will then need Information Governance and Finance and ultimately SIRO approval.

14. Antivirus and Malware Protection

Antivirus and malware protection is the responsibility of the D&I Service to configure, maintain, and monitor. All Trust devices are required, where possible, to have the Trusts antivirus and malware software installed. Any exceptions must be agreed by the D&I Service with appropriate mitigations in place.

Devices which are unable to have the standard security software are required to have alternative precautions configured to protect against viruses and malware. Where on-device protection is not possible, the device(s) must be segregated from other devices on the network.

15. Removable Storage Devices and Media

All Trust devices, where possible, will have Endpoint Control software installed to restrict removable media devices allowing data to be written only to approved, secure products.

Removable storage including laptops, memory sticks and CDs must be encrypted to AES 256bit standards. Disposal is via the Digital & Innovation Services (D&I) Service Desk. The D&I Service can provide guidance on how best to do this.

16. Internet, Email and Cloud Storage

Use of the Internet is defined in the Internet Use Policy.

Use of email is defined in the NHSMail Acceptable Use Policy. Emails containing confidential or personal identifiable data can be sent between NHSMail addresses, however email is not a clinical record, and it should not be used as an archive.

NHSMail email addresses should not be used on non-work-related-websites.

NHSMail and Active Directory (Windows Login) passwords must not be used on non-work-related websites or applications.

Personally identifiable or confidential information can be sent from NHSMail to non-NHSMail addresses by using the encrypted [SECURE] email function. Guidance on usage is available with the NHSMail encryption Guide.

Under no circumstances should confidential, sensitive or personal identifiable data be uploaded to and stored within personal consumer or commercial cloud storage services. Use of these services is only permissible for anonymised data or publicly available documentation.

The OneDrive, SharePoint and Teams components of the NHSMail Central Tenant M365 is approved for the exchange of clinical/sensitive data in line with the National Clinical Safety Case. NHS England has endorsed MS Teams as being the only approved secure communication platform for the exchange of patient and clinical information, clinical filing and the temporary storage of clinical and medical documents etc. Given this, the Trust, Information Governance and the Information Security Standards have sanctioned and approved the use of MS Teams within UHP for this purpose. No other system of this kind has this authorisation and clearance. Clinical data created in M365 should always be moved to the main clinical record.

A request to the D&I Service and Information Governance team will need to be made to use 'Microsoft Forms' as part of M365 as a data protection impact assessment may need to be completed.

17. Change Control

The D&I Service conducts changes to electronic information assets in accordance with its Change Enablement Standard Operating Procedure.

18. Assurance

Each system or collection of information assets which contain personal identifiable data will have a nominated Information Asset Administrator (usually the system manager) responsible for the creation and on-going review of the System Level Security Policy (SLSP) and accompanying risk assessment. SLSPs will be reviewed annually.

19. Business Continuity and Disaster Recovery.

The organisation will ensure that business continuity and disaster recovery plans are produced for all critical information, applications, systems, and networks. It is the responsibility of system managers and/or Information Asset Owners to ensure that this is kept up to date, recorded in System Level Security Policies and revised annually.

20. Security Incidents

All security incidents and weaknesses relating to any information asset are to be reported to the D&I Service Desk immediately and any compromise to patient safety, confidentiality or integrity of the clinical record should be reported on Datix and to the Information Governance Team.

Security incidents will require immediate attention and may require the isolation or removal of impacted equipment to protect the wider infrastructure and for remediation and/or forensic investigation.

Staff members that compromise security may be subject to disciplinary action in line with the Trust's Conduct Policy.

21. Digital Forensics

Digital forensic techniques can be used for many purposes, such as supporting the investigation of crimes and the breach of internal policies, analysis of security incidents, reviews of operational problems and procedures, and recovery from accidental system damage by giving assistance to the business continuity plans of the Trust.

Where an area of criminal activity is determined, particularly where there is suspicion of a breach of either the Protection of Children Act 1978, Section 1, or Section 160 of the Criminal Justice Act 1988, the Chief Information Security Officer, Head of Information Governance and Senior Information Risk Officer must be informed in the first instance and a report made to the police by the Cyber Security Team. Evidence collection, examination, and analysis must be conducted by the Cyber Security Team unless it is initially determined that the Police should handle the investigation from the start. This applies to any stage of an internal investigation.

All requests for forensic data will be forwarded to the Chief Information Security Officer who will seek authority from the Head of Information Governance/Data Protection Officer, Human Resources, and the Senior Information Risk Owner or Counter Fraud as appropriate, before any data is released final ratification will be sought from the Chief Information Officer. The Information Asset Owner will ensure those copies of data are available and that storage and segregation of both the original and copy data is completed.

The Senior Information Risk Owner will manage the communication of the investigation both internally and externally as required, including notification to external agencies such as the Police, NHSE, internal departments such as People Advisory Team (Human Resources) and any media interest.

The results of any post incident analysis must be reported to the Chief Information Officer and the Senior Information Risk Owner who will determine, with the aid of the Chief Information Security Officer and the Head of Information Governance/Data Protection Officer, whether external support is required. Items to be reported may include: a description

of the actions employed; an explanation of how tools and procedures were selected; a determination of any other actions that must be performed, such as forensic examination of additional data sources, securing identified vulnerabilities, and improving existing security controls; and recommendations for improvements to policies, guidelines, procedures, tools, and other aspects of the forensic process.

All Trust users must report any potential information incident to Service Desk

22. Overall Responsibility for the Document

The design and process of review and revision of this policy will comply with the Development and Management of Formal Documents.

The review period for this document is set as five years from the date it was last ratified, or earlier if developments within or external to the Trust indicate the need for a significant revision to the procedures described.

This document will be reviewed by the D&I Services SMIT, D&I Services SLG, Caldicott & Information Governance Assurance Committee and ratified by the Senior Information Risk Owner.

Non-significant amendments to this document may be made, under delegated authority from the Senior Information Risk Owner, by the nominated owner. These must be ratified by the Senior Information Risk Owner.

Significant reviews and revisions to this document will include a consultation with named groups, or grades across the Trust. For non-significant amendments, informal consultation will be restricted to named groups, or grades who are directly affected by the proposed changes.

23. Dissemination and Implementation

Following approval and ratification, this policy will be published in the Trust's formal documents library and all staff will be notified through the Trust's normal notification process.

Document control arrangements will be in accordance with The Development and Management of Formal Documents.

The document owner will be responsible for agreeing the training requirements associated with the newly ratified document with the named Senior Information Risk Owner and for working with the Trust's training function, if required, to arrange for the required training to be delivered.

24. Monitoring Compliance and Effectiveness

Compliance with this policy will be monitored by the completion of the Data Security and Protection Toolkit (DSPT) submission process, along with various security related tooling and reporting through the IT Service Desk. The evidence submitted for DSPT is subject to annual audit. Further specific Cyber Security reports are presented at Caldicott & Information Governance Assurance Committee and the Audit and Risk Assurance Committee (ARAC).

Data Security and Protection Toolkit update reports will be presented by the Information Governance Team to the Caldicott & Information Governance Assurance Committee.

The Cyber Security Team will monitor national and local developments that may affect this policy.

The Cyber Security Team will utilise the monitoring tools available to them to ensure compliance with this policy.

The D&I Service will monitor installed software for applications which have been installed without prior authorisation or have the potential to introduce increased risk to data contained therein.

Changes to information systems will be assessed and reviewed by the D&I Services Change Advisory Board.

The Cyber Security Team will review and update this policy in line with output from monitored systems.

25. References and Associated Documentation

Data Protection Act 2018/General Data Protection Regulation - [Data protection: The Data Protection Act - GOV.UK \(www.gov.uk\)](https://www.gov.uk/data-protection-the-data-protection-act)

Freedom of Information Act 2000 (further information on the Information Commissioner's Office website – [Freedom of Information Act 2000 \(legislation.gov.uk\)](https://www.legislation.gov.uk/ukpga/2000/36/contents))

Information Security Management: NHS Code of Practice

[Information Security Management: NHS Code of Practice - GOV.UK \(www.gov.uk\)](https://www.gov.uk/information-security-management-nhs-code-of-practice)

Data Security and Protection Toolkit

<https://www.dsptoolkit.nhs.uk>

Clinical Safety Standards

[DCB160 \(Clinical Risk Management: its Application in the Deployment and Use of Health IT Systems\).](https://www.npsa.nhs.uk/clinical-risk-management/its-application-in-the-deployment-and-use-of-health-it-systems)

[DCB129 \(Clinical Risk Management: its Application in the Manufacture of Health IT Systems\).](https://www.npsa.nhs.uk/clinical-risk-management/its-application-in-the-manufacture-of-health-it-systems)

Copyright, Designs and Patents Act (1988)

<http://www.legislation.gov.uk/ukpga/1988/48/contents>

Computer Misuse Act (1990)

<http://www.legislation.gov.uk/ukpga/1990/18/contents>

Human Rights Act (1998)

<http://www.legislation.gov.uk/ukpga/1998/42/contents>

Regulation of Investigatory Powers Act (2000)

<http://www.legislation.gov.uk/ukpga/2000/23/contents>

Instant Messaging

[Using mobile messaging - NHS Transformation Directorate \(england.nhs.uk\)](#)

NHS Records Management Code of Practice for Health and Social Care 2023
[NHSX Records Management CoP V7.pdf \(england.nhs.uk\)](#)

StaffHub Network Security Policy

Trust Network Security policy

NHSE MFA Policy

[Multi-factor authentication \(MFA\) policy - NHS England Digital](#)

NHSMail Acceptable Use Policy

[NHSMail 2 Portal - Home](#)

Encryption Guide for NHSMail

[Encryption Guide for NHSMail – NHSMail Support](#)

NHS Mail Password Policy

[NHSMail password policy – NHSMail Support](#)

Appendix 1. Dissemination and Review Checklist

Dissemination Plan			
Document Title		Information Security Policy	
Date Finalised		October 2024	
Previous Documents			
Action to retrieve old copies		To be managed by the Document Controller	
Dissemination Plan			
Recipient(s)	When	How	Responsibility
All Trust staff	October 2024	Document Library on StaffHub Page	Document Controller

Review Checklist		
Title	Is the title clear and unambiguous?	Yes
	Is it clear whether the document is a policy, procedure, protocol, framework, APN, or SOP?	Yes
	Does the style & format comply?	Yes
Rationale	Are reasons for development of the document stated?	Yes
Development Process	Is the method described in brief?	Yes
	Are people involved in the development identified?	Yes
	Has a reasonable attempt has been made to ensure relevant expertise has been used?	Yes
	Is there evidence of consultation with stakeholders and users?	Yes
Content	Is the objective of the document clear?	Yes
	Is the target population clear and unambiguous?	Yes
	Are the intended outcomes described?	Yes
	Are the statements clear and unambiguous?	Yes
Evidence Base	Is the type of evidence to support the document identified explicitly?	Yes
	Are key references cited and in full?	Yes
	Are supporting documents referenced?	Yes
Approval	Does the document identify which committee/group will review it?	Yes
	If appropriate have the joint People Advisory Team (Human Resources)/staff side committee (or equivalent) approved the document?	Yes
	Does the document identify which Executive Director will ratify it?	Yes
Dissemination & Implementation	Is there an outline/plan to identify how this will be done?	Yes
	Does the plan include the necessary training/support to ensure compliance?	Yes
Document Control	Does the document identify where it will be held?	Yes
	Have archiving arrangements for superseded documents been addressed?	Yes
Monitoring Compliance & Effectiveness	Are there measurable standards or KPIs to support the monitoring of compliance with and effectiveness of the document?	Yes
	Is there a plan to review or audit compliance with the document?	Yes
Review Date	Is the review date identified?	Yes
	Is the frequency of review identified? If so, is it acceptable?	Yes
Overall Responsibility	Is it clear who will be responsible for co-ordinating the dissemination, implementation, and review of the document?	Yes

Appendix 2. Equalities and Human Rights Impact Assessment

Core Information	
Date	October 2024
Title	Information Security Policy
What are the aims, objectives & projected outcomes?	The Information Security Policy will establish and maintain the security and confidentiality of information assets, information systems, applications, and networks.
Scope of the assessment	
This assessment will highlight any areas of inequality with the implementation of this policy.	
Collecting data	
Race	This is mitigated as the policy can be made available in alternative languages.
Religion	The document has no impact in this area.
Disability	This is mitigated as the policy can be made available in alternative formats.
Sex	The document has no impact in this area.
Gender Identity	The document has no impact in this area.
Sexual Orientation	The document has no impact in this area.
Age	The document has no impact in this area.
Socio-Economic	The document has no impact in this area.
Human Rights	The document has no impact in this area.
What are the overall trends/patterns in the above data?	There are no trends/patterns in this data. External consideration has been given to 2011/12 NHS Litigation Authority Risk Management Standards for NHS Trusts, Care Quality Commission Outcomes, and Information Governance Toolkit requirements.
Specific issues and data gaps that may need to be addressed through consultation or further research	Trust wide documents can be made available in several different formats and languages if requested. No further research is required as there are no further equality issues.

Involving and consulting stakeholders				
Internal involvement and consultation	This policy has been compiled by the D&I the Chief Information Security Officer, Information Security Officer and Cyber Security Team. The policy has been circulated for consultation to members of the D&I Senior Management Team and the Caldicott and Information Governance Group.			
External involvement and consultation	External consideration has been given to 2011/12 NHS Litigation Authority Risk Management Standards for NHS Trusts, Care Quality Commission Outcomes, and Information Governance Toolkit requirements.			
Impact Assessment				
Overall assessment and analysis of the evidence	This assessment has shown that there could be an impact on race or disability groups. However, this document can be made available in other formats and languages if requested. The document does not have the potential to cause unlawful discrimination. The document does not have any negative impact.			
Action Plan				
Action	Owner	Risks	Completion Date	Progress update
Provide document in alternative formats and languages if requested.	Information Governance Team	Potential cost impact.	Ongoing	This action will be addressed as and when the need occurs.